

A thick dark grey vertical bar is positioned on the left side of the page. To its right, several thin, curved lines in dark grey and light grey sweep upwards and outwards from the bottom left corner.

4-9-2026

ACTIVIDAD 01: ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

HACKER WOMEN COUNCIL – ETHICAL HACKER

Instructora: Aleida Pérez

Alumna: Valentina Belén Dolce

1. OBJETIVO DEL PENTEST: Define 3 objetivos concretos que tendría la evaluación de seguridad de Aurora Market

1) Evaluar la exposición real y el impacto en el negocio

El equipo debe identificar las vulnerabilidades para entender los riesgos reales, cómo estos podrían afectar a la empresa, y definir qué medidas de mitigación se deben tomar: no se trata solamente de generar una lista de problemas técnicos, sino de evaluar qué tan expuesta está realmente la aplicación web. Porque los ciberataques son una cuestión de cuándo, no de sí o no.

2) Analizar los controles de acceso con información parcial

Como el cliente nos autoriza a realizar pruebas únicamente sobre la aplicación web, nuestro equipo no cuenta con toda la información técnica de la totalidad de su infraestructura. Por esta razón es clave evaluar la seguridad de este componente conocido para determinar qué vectores de ataque podría descubrir un actor malicioso, basándose en la información disponible.

3) Validar de forma segura la sospecha de vulnerabilidad reportada, y ofrecer mitigaciones efectivas en caso de ser confirmada.

Tomando como premisa el problema reportado previamente por un usuario, el equipo tiene la tarea de investigarlo para confirmar si corresponde realmente a una vulnerabilidad explotable y, de ser así, indicarle al equipo de desarrolladores de Aurora Market cómo mitigarla. Quizás fue un primer indicio de un posible ataque, siendo esta señal un error que cometió un ciberatacante mientras exploraba las posibles puertas de entrada hacia Aurora Market.

2. ALCANCE: Identifica claramente qué se evaluará y qué queda fuera del alcance:

a) SI SE EVALUARÁ

Sólo se realizarán pruebas en la aplicación web autorizada de Aurora Market, incluyendo su base de datos, mecanismos de autenticación (de estar implementados) y diferentes tipos de usuarios asociados a dicha aplicación (para poder investigar correctamente el problema reportado).

b) FUERA DEL ALCANCE

Las cuentas en redes sociales de Aurora Market no estarán incluidas en el alcance. No se tendrán en cuenta los equipos personales de los empleados con sus respectivas cuentas de correo electrónico y tampoco se evaluará a proveedores externos.

3. AUTORIZACIÓN Y CONDICIONES: Explica qué permisos y condiciones deben estar definidos antes de comenzar las pruebas.

a) PERMISOS REQUERIDOS

Un contrato con una autorización formal por escrito que detalle explícitamente el consentimiento otorgado por Aurora Market a nuestro equipo para realizar las pruebas de penetración sobre su aplicación web objetivo. Aurora Market también deberá proveer el acceso a la plataforma, junto con las credenciales necesarias para evaluar los diferentes tipos de usuarios y los posibles mecanismos de autenticación implementados.

b) CONDICIONES ACORDADAS

La delimitación estricta del alcance por parte de Aurora Market especifica que las pruebas deben realizarse única y exclusivamente sobre la aplicación web autorizada, con todos los componentes relacionados a la misma. De esta manera, queda prohibido evaluar o atacar las cuentas en redes sociales de la empresa, los equipos personales de los empleados y sus cuentas de correo electrónico; como así también a proveedores externos u otros sistemas no acordados.

Nuestro equipo se compromete a garantizar la continuidad del negocio, por este motivo las evaluaciones técnicas deberán ejecutarse durante las horas de baja demanda operativa (para minimizar riesgos sobre los usuarios activos) y se prohíbe realizar acciones que puedan degradar la plataforma o interrumpir deliberadamente su funcionamiento (como ataques de denegación de servicio). En cuanto a la protección de datos (tanto de Aurora Market como de sus clientes), las pruebas no deben alterar, comprometer ni afectar la información real de los clientes.

Por último, todo problema o vulnerabilidad detectada debe ser documentado cuidadosa y detalladamente para que el equipo de desarrollo de Aurora Market pueda corregirlo eficazmente.

4. TIPO DE PENTEST: Determina si el escenario corresponde a un: Black-box, Gray-box o White-box. Investiga brevemente el concepto y justifica tu elección.



El escenario corresponde perfectamente con un pentest Gray-box, ya que es el mejor enfoque para investigar el problema reportado dado el limitado alcance que nos permite Aurora Marquet. A diferencia del pentest Black-Box donde se simula un ataque completamente a oscuras, o en el White-Box donde se recibe total acceso a la información e infraestructura interna; el equipo cuenta con conocimiento estructural básico (autenticación, roles y base de datos) que corresponde con la definición del penetration test Gray-Box. Como Aurora Market quiere saber específicamente qué podría descubrir un atacante dependiendo de la información que este tenga disponible, el recibir credenciales para los diferentes tipos de usuarios con los que comercian nos permitiría evaluar la seguridad desde la perspectiva de un usuario legítimo pero malintencionado (o con una cuenta comprometida), pudiendo también investigar los distintos vectores de ataque basándonos en los niveles de privilegio que el atacante logre obtener. Tener un contexto parcial ayuda al equipo a dirigir los esfuerzos técnicos hacia la validación de ese incidente específico, simulando las condiciones bajo las cuales ese usuario detectó la anomalía.

5. **PLANIFICACIÓN:** Establece qué debería hacer el equipo antes de comenzar la parte técnica. Completa los elementos clave.
- a) **OBJETIVOS:** detallado en el ítem 1
 - b) **ALCANCE:** detallado en el ítem 2
 - c) **PERMISOS Y CONDICIONES:** detallado en el ítem 3
 - d) **METODOLOGÍA A UTILIZAR:** PTES (Penetration Testing Execution Standard) para organizar las fases generales del proyecto (desde la planificación hasta el reporte final) y OWASP WSTG (Web Security Testing Guide) durante la ejecución del pentest.
 - e) **RECOPIACIÓN DE INFORMACIÓN PREVIA:** analizar en profundidad el problema reportado por el cliente con su debido contexto, identificar qué tecnologías utiliza la plataforma y gestionar con Aurora Market los usuarios con diferentes roles asignados para poder evaluar los controles de acceso sin usar cuentas reales.
 - f) **RECURSOS NECESARIOS:** definir un canal de comunicación entre Aurora Market y nuestro equipo, para poder informar en caso de alguna inestabilidad en la aplicación web o para pedir algún acceso no otorgado; proxies de intercepción (como Burp Suite o OWASP ZAP) para analizar el tráfico web, herramientas para enumeración y explotación manual; direcciones IP estáticas de nuestro equipo (para que Aurora Market las ponga en "lista blanca" y sus firewalls no bloqueen las pruebas legítimas).
 - g) **PROGRAMACIÓN DEL PENTEST:** definir las franjas horarias específicas permitidas para las pruebas técnicas; y las fechas de inicio, ejecución de pruebas y entrega del informe final.

6. FASES DEL PENTEST: Explica cómo aplicarías cada fase al caso de Aurora Market. ¿Qué buscarías hacer en cada etapa?
- 1) **RECONOCIMIENTO**: iniciar sesión con cada uno de los diferentes usuarios con distintos niveles de privilegios e interactuar con la aplicación web para mapear la superficie de ataque.
 - 2) **ANÁLISIS DE VULNERABILIDADES**: con la información recolectada durante el reconocimiento, plantear hipótesis y buscar debilidades en los diversos componentes y niveles de la aplicación web.
 - 3) **EXPLOTACIÓN**: intentar vulnerar los componentes de la aplicación identificados como puertas de entrada. Simular diversas técnicas de ataque para confirmar (si las vulnerabilidades encontradas son reales y explotables) o descartar las hipótesis planteadas.
 - 4) **POST-EXPLOTACIÓN**: determinar el impacto, probabilidad y riesgo de las vulnerabilidades activamente expuestas. Cuantificar en números el impacto real y los riesgos del negocio.
 - 5) **INFORME**: documentar exhaustiva y detalladamente tanto el procedimiento seguido para encontrar las vulnerabilidades (con su debida evidencia), como las recomendaciones de mitigación que debe aplicar el equipo de desarrolladores de Aurora Market para proteger el activo.
7. INVESTIGACIÓN: Consulta al menos una de las metodologías que revisamos en clase y explica por qué podría ser útil para este proyecto
- a) **METODOLOGÍA ELEGIDA**: OWASP WSTG (Web Security Testing Guide)
 - b) **¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?** La metodología OWASP WSTG sería útil para la ejecución técnica en el proyecto de Aurora Market, ya que es el estándar de la industria para evaluar aplicaciones web (nuestro alcance limitado). OWASP nos proporciona las metodologías exactas para auditar estos componentes específicos sin salirnos del alcance, sumado a que cuenta con secciones muy detalladas y al alcance de todos sobre cómo testear las diferentes categorías de vulnerabilidades web, con sus respectivas guías de mitigación. Dado que Aurora Market solicitó que los problemas se documenten cuidadosamente para sus desarrolladores, el utilizar la nomenclatura y las guías de remediación de OWASP facilita enormemente que los programadores entiendan la raíz del problema y lo corrijan de manera eficiente.